

Privacy Analysis and Repair

NeurOne Design Programme

NP-PRIV-001 Rev 1
Date: 2026-06-02
Classification: CONFIDENTIAL — Internal Use Only
Scope: CLAUDE.md Rev 14 · UHDR/SHDR architecture · Consent engine · Research data flows · Clinical platform

Severity	Count	Status
CRITICAL	2	Action required immediately
HIGH	6	Resolve before T1 launch
MEDIUM	7	Resolve before T2 / EU launch
LOW	3	Address in next planning cycle

Summary

The NeurOne privacy architecture is more sophisticated than almost any consumer health device reviewed. The UHDR/SHDR separation, biometric-key encryption, on-device anonymisation, and use-case-based clinical consent engine are genuine structural strengths. The 18 findings below are therefore concentrated in gaps and edge cases rather than foundations.

Jurisdictions in scope: United States primary (HIPAA, FTC HBNR, CCPA/CPRA, FTC Act §5, state breach laws); EU/EEA secondary (GDPR, ePrivacy Directive) — EU market is anticipated and the charger policy already addresses it.

Highest-leverage single change: Resolve the Warranty Owner ID Critical finding before any external beta or warranty registration goes live. If SHDR is effectively person-linked, the UHDR/SHDR privacy firewall — the core architectural claim — is undermined.

Critical Findings

CRITICAL	Warranty Owner ID re-identifies SHDR
WHERE	CLAUDE.md §5.1 — SHDR definition; §5.1 boundary resolution table; NP-FW-EMMC-001 Rev 1 §7
CATEGORY	Pure privacy failure
ISSUE	SHDR is documented as 'linked to device ID + warranty owner ID only — never to user identity.' But warranty registration collects name, email, postal address, and serial number. If 'warranty owner ID' is a pointer into that table, SHDR is person-linked and the privacy firewall collapses. NeurOne would hold session counts, LED usage ratios, temperature profiles, consumable patterns, and impact events tied to a named individual — health data by inference. Under HIPAA this likely qualifies as PHI; under GDPR Art. 9 inferrable health data requires explicit consent.
REFERENCE	Linkable Identifiers anti-pattern; Inference Without Consent anti-pattern; HIPAA Privacy Rule Minimum Necessary; GDPR Art. 9 (special-category data); LINDDUN — Identifiability
REMEDIATION	Introduce an opaque 256-bit warranty token. Store (token → name, email, address) in the warranty system only. Store only the token in SHDR. The warranty database and SHDR fleet database are never joined in production. Add a SHDR boundary test: 'Could NeurOne identify a named individual from SHDR plus the warranty registration table?' If yes → the data is UHDR. Document in NP-FW-EMMC-001 Rev 2 and NP-RM-001.

CRITICAL	No documented breach detection or response plan
WHERE	CLAUDE.md §13 (absent); NP-QMS-CAPA-001 Rev 1 — regulatory reporting mentioned but no breach runbook
CATEGORY	Pure privacy failure
ISSUE	The QMS documents CAPA triggers but there is no breach detection, containment, or notification runbook. Hard regulatory deadlines apply: HIPAA Breach Notification Rule — 60 days from discovery for individual notification; FTC HBNR (applies to T1 as non-HIPAA wellness device) — updated 2024 to cover more PHR-adjacent vendors; US state laws — 30–90 days across all 50 states; GDPR Art. 33–34 — 72 hours to supervisory authority, high-risk breaches require individual notification without undue delay. A first breach response without a runbook will exhaust the clock.
REFERENCE	OWASP Top 10 Privacy Risks P3; Data Breach Notification Pattern; HIPAA 45 CFR §164.400–414; FTC HBNR 16 CFR Part 318; GDPR Art. 33–34
REMEDIATION	Author NP-SEC-BR-001 (Breach Response Plan) as a Month 3 deliverable. Minimum contents: detection signals (anomalous SHDR upload volumes, unusual admin access to warranty DB); severity tiers triggering HIPAA / HBNR / GDPR Art. 33; escalation chain with named roles; pre-drafted notification templates; forensic log retention confirmed to outlast the longest notification window (HIPAA: 6 years); annual tabletop exercise before T1 launch.

High Findings

HIGH	SHDR impact-event data enables motor-health inference
WHERE	CLAUDE.md §5.1 boundary resolution table — 'impact events (g-force, orientation — between sessions only) → SHDR'
CATEGORY	Pure privacy failure
ISSUE	The boundary rule assigns between-session impact events to SHDR on the logic that they reveal device condition rather than user biology. This fails the project's own test: 'does this tell us something about the person?' A user who drops the device repeatedly, or has a consistent high-g drop signature, is revealing motor control information. Parkinson's, essential tremor, post-stroke hemiplegia, and MS all manifest in device drop patterns. Combined with the warranty owner ID (Critical finding), NeurOne would hold health-inferable data on named individuals.
REFERENCE	Inference Without Consent anti-pattern; Aggregation Creep anti-pattern; LINDDUN — Identifiability; GDPR Art. 9; FTC Act §5

**REMEDIA
TION**

Option A (quick): coarsen to binary flag (drop_detected: true/false, no g-force value or orientation). Option B (recommended): move raw impact-event data to UHDR; expose only a derived SHDR metric — 'drop rate above maintenance-alert threshold: true/false.' Option C (strongest): on-device processing only, emit the binary alert to SHDR, raw accelerometer series never leaves the device. Adopt Option B as minimum. CONCLUSION (principal decision, 2026-08-12 — NP-FW-EMMC-002 Rev 2 §H). Option C remains the destination; it is not superseded. It is, however, unreachable as written, and the reason is a defect in this finding's own remediation rather than in the finding. Option C says 'process on-device' — but the two thresholds that define the processing (NP_ACCEL_DROP_THRESHOLD_G = 15.0f; the maintenance rate) are unvalidated guesses made before any hardware existed, and the Option B/C prohibition forbids collecting the very data that would validate them. Nobody has established what impact profile predicts device failure. The remediation therefore forecloses the evidence needed to make the remediation correct. The resolution is a bounded, self-closing characterisation programme that obtains that evidence and then retires itself, on the pattern NP-MOD-ID-001 §7 set for the DOSE-01 relaxation. During a time-boxed window an enrolled device additionally emits a COARSENEED per-gap histogram of impact peaks — counts per fixed bin, never a raw series, never a per-event g value, never an orientation vector, never a per-event timestamp. Collection is opt-in and revocable, consented by the WARRANTY OWNER, and purpose-bound to predictive-maintenance model training only: not to research, not to warranty adjudication, not to any per-device determination affecting an owner. At window close the extended rows are DELETED from the fleet database — the fitted model survives, the evidence does not. The window is denominated in RECORDS, not calendar time, because this device has no clock that survives being unplugged: it is USB-C powered with no battery or coin cell, so the SNVS RTC has no backup domain and wall time is re-supplied by the phone. A calendar expiry would be both losable and settable backwards. A per-device record budget is monotone by construction, needs no clock, and is the quantity the review gate actually needs — so exhausting the budget and answering the question are the same act. Expiry is enforced fail-closed in firmware by a build-time constant, and CI enforces the biconditional in both directions: a closed window whose schema still carries the extended columns FAILS, so the data cannot outlive the programme. WHY REGISTRANT CONSENT SUFFICES. Per NP-MOD-ID-001 §7.5.1, 'the operative distinction is between describing a person and being attributable to one.' SHDR holds no user identifier; the warranty database — which SHDR cannot join — names the REGISTRANT, not the wearer; and nothing in either store records the relationship between them. Consent is owed to an identifiable subject, and there is none in any device configuration, so the registrant may consent in all of them. AND THE ARGUMENT IS STRONGER HERE THAN IN THE CASE ALREADY DECIDED. The module duty-map programme accepted registrant consent for data that at least requires the device to be WORN — a duty map is a record of a wearing session. A DROP DOES NOT. The headset can be dropped by a family member moving it off a table, by clinic staff cleaning it, by a courier, by anyone handling it. So on the 'describes a person' limb — the limb that made the duty-map case arguable at all — impact data is weaker, not merely equal: an impact histogram is frequently not a record of the wearer's behaviour, and nothing in it marks which entries are. The precedent is followed a fortiori, not merely cited. SEPARATELY, AND NOT CREATED BY THIS DECISION: the Option A/B prohibition is already defeated by aggregation. shdr_accel_records is append-per-gap with a non-unique warranty_token, so a COUNT of drop_detected rows per token IS the 'drop count as an integer' the schema bans by name, and the gap_index values where it is true ARE the inter-drop timing that banning per-event timestamps was meant to prevent. A column-level control cannot express a row-set-level hazard. Recorded as OI-EMMC2-11 for principal decision; it is stated here so that this finding's remediation is not read as more complete than it is.

HIGH	k-anonymity alone is insufficient for research data
WHERE	CLAUDE.md §5.3 — 'k≥10 anonymisation'; §6.2 — L3 blanket consent; §6.3 — study descriptor
CATEGORY	Pure privacy failure
ISSUE	The research anonymisation relies on k-anonymity ($k \geq 10$) with date-rounding and quasi-identifier suppression. k-anonymity has two known critical vulnerabilities: (1) homogeneity attack — if all 10+ individuals share the same EEG band-power profile, the value is revealed exactly; (2) background knowledge attack — if an adversary knows a target person is in a study, they can infer a diagnosis even without a direct identifier. EEG patterns are biometric and are as identifying as fingerprints over time.
REFERENCE	k-anonymity failure modes (Sweeney 2002, Machanavajjhala 2006); Re-identification via Join anti-pattern; AOL search logs (2006); Netflix Prize (2007); GDPR Recital 26
REMEDIATION	Upgrade to l-diversity ($l \geq 3$) in addition to k-anonymity. For any EEG waveform extract, require differential privacy ($\epsilon \leq 1.0$, $\delta \leq 10e-5$) via calibrated Laplace or Gaussian noise applied to spectral features. Prohibit raw EEG waveforms from research extracts regardless of k — only derived features with DP noise. Add language to L3 and per-project consent that 'anonymisation means statistical protection, not mathematical certainty' and names EEG as biometric-adjacent. Reference: NIST SP 800-226.

HIGH	UHDR key lifecycle gap: biometric revocation and device transfer
WHERE	CLAUDE.md §5.1 UHDR encryption spec; NP-FW-EMMC-001 Rev 1 §6
CATEGORY	Pure privacy failure + security failure
ISSUE	Two lifecycle gaps are unaddressed. (1) Biometric compromise or change: Argon2id is deterministic — if the biometric template changes, the derived key changes and previously encrypted UHDR becomes inaccessible. No key-rotation path or fallback is specified. (2) Device resale: if a user sells the device, UHDR ciphertext remains on the device, SHDR persists with the old user's session history, and the new owner may register a new warranty token on top of the old user's hardware fingerprint.
REFERENCE	Permanent Storage anti-pattern; GDPR Art. 17 (erasure must extend to all copies including device); HIPAA Security Rule §164.310(d)(1) — media and device disposal
REMEDIATION	Key rotation: document in NP-FW-EMMC-001 a two-layer key scheme — UHDR master key (random, stored in Config partition encrypted with Argon2id key) so biometric change only re-encrypts the wrapper, not the full partition. Device transfer flow: (a) user initiates reset in app, (b) UHDR partition overwritten with eMMC SANITIZE, (c) SHDR reset to fresh device-ID-only state with session counter zeroed, (d) warranty owner token cleared from Config partition, (e) device generates new HKDF-based SHDR key with new TRNG salt.

HIGH	Mode F autonomous retinal PBM — consent capture undefined
WHERE	CLAUDE.md §3 Visual Stimulation — 'Mode F (invisible NIR retinal walk): 808-830nm daily retinal PBM during normal-looking wear'
CATEGORY	Pure privacy failure (consent gap)
ISSUE	Mode F delivers therapeutic PBM to the retina during 'normal-looking wear' — while the goggles appear inactive. This is the highest-sensitivity modality from a consent standpoint: it operates without an obvious session boundary, delivers NIR radiation to the retina (the one modality with a hardware MPE limit under IEC 62471), and generates UHDR data (eye-open/closed state) during apparently ambient wear. No documented consent capture exists for Mode F specifically.
REFERENCE	Obtaining Explicit Consent pattern; GDPR Art. 7 (consent must be specific and informed); GDPR Art. 9(2)(a) (explicit consent for health data); HIPAA Minimum Necessary; IEC 62471 (retinal MPE)
REMEDIATION	Add Mode F as an explicitly named, separately consented feature. Default: OFF. User must take a deliberate action to enable it (Cavoukian Principle 2: Privacy as Default). Add a persistent ambient indicator when Mode F is active — e.g. the right temple status LED breathes a distinct pattern (per §4.7). Clarify in NP-FW-EMMC-001 §12 how Mode F data is classified and stamped in the session record.

HIGH	Clinician consent revocation path not specified
WHERE	CLAUDE.md §6.1 — 'per-element, per-use-case, time-limited, audited, revocable'
CATEGORY	Pure privacy failure
ISSUE	The consent engine states clinician access is 'revocable' but no mechanism is documented. Open questions: What happens to UHDR data already reviewed when a patient revokes? Can a patient revoke mid-subscription? Is revocation immediate or at the next billing cycle? Is the API access token invalidated immediately? For T2 multi-patient dashboards, are historical records removed from the dashboard view on revocation?
REFERENCE	Enable/Disable Functions pattern; GDPR Art. 7(3) — withdrawal must be as easy as granting consent and immediately effective; HIPAA §164.522 (individual right to restrict); Selective Access Control pattern
REMEDIATION	Define revocation as an API-level capability — token invalidation within seconds of user action. Document the clinician UX when a patient revokes (record greyed/removed; data in clinician possession subject to their own HIPAA BAA obligations). Add a revocation log to SHDR (no UHDR content — just revocation flag, timestamp, tier). Clarify billing position in the BAA template: revocation terminates access regardless of remaining subscription term.

HIGH	POA document upload is an unspecified high-risk data flow
WHERE	CLAUDE.md §6.2 — 'POA holder uploads executed healthcare POA → human review 3 business days'
CATEGORY	Security failure + pure privacy failure
ISSUE	A healthcare Power of Attorney document contains the grantor's legal name, date of birth, address, health conditions that triggered the POA, and the identity of the attorney-in-fact. The upload flow is described in one sentence with no specification for: how the document is transmitted; where it is stored; which NeurOne employees can access it; retention period; whether document content is indexed; or what happens on acquisition. This is a God View risk for the POA processing team.
REFERENCE	God View anti-pattern; Least Privilege pattern; Permanent Storage anti-pattern; GDPR Art. 9(2)(c) (vital interests — specific safeguards required); HIPAA Security Rule §164.312 (access controls for sensitive PHI)
REMEDIATION	Require end-to-end encrypted upload via signed URL (document goes directly to encrypted storage, not through application servers). Separate vault with field-level encryption; access restricted to named reviewers only (2-3 people max); every access logged. Delete the original document within 30 days of human review; retain only structured review output (jurisdiction code, scope summary, expiry date, verification timestamp). Author NP-PROC-POA-001 before T1 launch.

Medium Findings

MEDIUM	FHIR R4 minimum population not bounded
WHERE	CLAUDE.md §3 T2 — 'HIPAA cloud + EHR: FHIR R4'; LSL streaming
CATEGORY	Pure privacy failure
ISSUE	FHIR R4 Patient resources support name, DOB, address, phone, email, SSN, race, ethnicity, and more. Without a NeurOne FHIR profile specifying exactly which resource types and fields are populated, implementations default to 'populate what the spec allows' — bringing substantial unnecessary PII into T2. Additionally, LSL (Lab Streaming Layer) has no native encryption or authentication and streams on the local network in plaintext. In a clinical environment, an unencrypted LSL stream carrying real-time EEG or HRV from a named patient is a significant exposure.
REFERENCE	Collect Now, Decide Later anti-pattern; HIPAA Minimum Necessary Rule 45 CFR §164.502(b); HL7 FHIR R4 Privacy Module §3.3; LINDDUN — Disclosure of information
REMEDIATION	Define a NeurOne FHIR ImplementationGuide before any T2 EHR integration is built. Permitted resources: Patient, Observation, DiagnosticReport, Procedure. Patient.identifier: opaque clinic-assigned MRN only. Patient.birthDate: year-only if clinically required. Explicitly prohibit: Patient.name, telecom, address, photo, contact. For LSL: require TLS tunnelling (stunnel or WireGuard VPN); state explicitly in setup guide and BAA that unencrypted LSL is not HIPAA-compliant. Add G3-09 to NP-COORD-001 gating T2 EHR integration on FHIR profile approval.

MEDIUM	Scripting API data access scope undefined
WHERE	CLAUDE.md §2.1 Pro Full — 'scripting API'; §3 T2 — 'scripting API'
CATEGORY	Pure privacy failure
ISSUE	The scripting API is a Pro Full feature with no specification of authentication model, data access scope, rate limits, or audit logging. In a multi-patient clinical environment, an API without explicit UHDR gating is a God View risk: a single compromised API key could enumerate sessions and access EEG or HRV features across every patient linked to the clinic account. This is OWASP API Security Top 10 items API1 (Broken Object Level Authorization) and API3 (Excessive Data Exposure) by design.
REFERENCE	God View anti-pattern; Least Privilege pattern; OWASP API Security Top 10 API1, API3; HIPAA Security Rule §164.312(a)(1) — access controls; HIPAA §164.312(b) — audit controls
REMEDIATION	SHDR-only by default (device telemetry, session counts, protocol parameters). UHDR-derived data requires: active clinical consent grant at Assess or Full Clinical tier; explicit API access toggle in the consent engine (not inherited from dashboard access); data type within consented use-case element list. Audit log: every patient-data API call logs timestamp, key fingerprint, patient token, resource type, response byte count; retained 6 years. Rate limits: 1,000 patient-record requests/hour, 10,000/day. 256-bit random keys, 90-day expiry. Author NP-API-001 as T2 pre-launch deliverable.

MEDIUM	Apple Watch sync app HealthKit access scope unspecified
WHERE	CLAUDE.md §3b Apple Watch Sync App; NP-APP-ROADMAP-001 Rev 1 Phases 1-4
CATEGORY	Pure privacy failure
ISSUE	The Watch app reads HRV data and potentially other HealthKit quantities. The roadmap does not specify which HealthKit types are requested. If the app follows a broad permission model, it would hold a far richer health profile than any session warrants — including sleep stages, workout history, blood oxygen, ECG readings, reproductive health, and more. Apple App Store Guideline 5.1.1(iv) prohibits using HealthKit data for user profiling. FTC enforcement against GoodRx (2023), BetterHelp (2023), and Premom (2023) establishes that sharing health app analytics without adequate disclosure is unfair regardless of HIPAA coverage.
REFERENCE	Collect Now, Decide Later anti-pattern; Apple HealthKit Review Guideline 5.1.1(iv); FTC Act §5 (GoodRx, BetterHelp, Premom precedents); GDPR Art. 9 (health data)
REMEDIATION	Phase 1 HealthKit permissions: HKQuantityTypeIdentifierHeartRateVariabilitySDNN and HKQuantityTypeIdentifierHeartRate only. No other types. HealthKit data stays on Watch/iPhone; used for real-time display only; not transmitted to NeurOne servers; not persisted beyond the session. Complete App Privacy Nutrition Label accurately before App Store submission. Add OI-WA-06: HealthKit permission review and privacy declaration sign-off as Phase 1 milestone.

MEDIUM	Research Scratch partition anonymisation window
WHERE	NP-FW-EMMC-001 Rev 1 §15; CLAUDE.md §5.1 — 'Scratch: raw blocks, no filesystem, no encryption'
CATEGORY	Security failure
ISSUE	The research anonymisation pipeline uses the Scratch partition as a working area. Scratch is explicitly unencrypted. Three exploitable windows: (1) unexpected power loss mid-anonymisation leaves plaintext UHDR data on Scratch until next boot; (2) cold-boot attack — NAND retains charge briefly after power-off; (3) partial eMMC block-level reads can access Scratch without decrypting UHDR since they share the same physical medium. For a device whose core security claim is 'NeurOne cannot read UHDR,' a cleartext UHDR window on the device is a meaningful vulnerability if a hostile party takes physical possession.
REFERENCE	OWASP Top 10 Privacy Risks P4; Cavoukian Principle 5 (end-to-end security); GDPR Art. 32; NIST SP 800-111 (storage encryption for portable devices)
REMEDIATION	Derive a one-time session key $K_{\text{scratch}} = \text{AES-256}(\text{TRNG}_{256}, \text{session_nonce})$ before the anonymisation task begins. Write all working data to Scratch using AES-256-CTR with K_{scratch} . Store K_{scratch} only in on-chip SRAM; zero with <code>memset_explicit</code> on completion or reset. Design the pipeline as an atomic transaction — interrupted runs are discarded, never partially transmitted. Issue eMMC SANITIZE (CMD38) on Scratch blocks after extract is written and verified. Document in NP-FW-EMMC-001 Rev 2 §15.

MEDIUM	EDF+ patient header field handling
WHERE	NP-FW-EMMC-001 Rev 1 §6 — session data stored as EDF+; CLAUDE.md §5.1 UHDR file structure
CATEGORY	Pure privacy failure
ISSUE	EDF+ file headers (first 256 bytes) contain mandatory plaintext fields: local patient identification (name, sex, DOB, patient code) and local recording identification (start date, hospital code, technician, equipment). If NeurOne follows clinical convention, every UHDR EDF+ file contains plaintext PII even though the partition is AES-256-XTS encrypted. When a user exports EDF+ to share with a clinician, they may inadvertently export name and DOB embedded in the header. Research anonymisation that strips data fields but not EDF+ headers is the Fake Anonymisation anti-pattern applied to file metadata.
REFERENCE	Strip Invisible Metadata pattern; Fake Anonymisation anti-pattern; GDPR Art. 5(1)(c) data minimisation; HIPAA Minimum Necessary; EDF+ specification §2.1
REMEDIATION	Define NeurOne EDF+ header policy in NP-FW-EMMC-001 Rev 2 §6. Patient code: opaque UHDR_TOKEN (16 chars). Sex: X (never populated). Birthdate: X. Patient name: X. Recording start date: preserved. Hospital code: 'NeurOne'. Technician: X. Equipment: 'NeurOne_v[FW_VER]'. For research anonymisation: add a header validation step that fails-closed if any non-X value appears in identity fields. For user export: display modal confirming file does not contain name or DOB.

MEDIUM	Clinician consent revocation cascade to third-party processors not specified
WHERE	CLAUDE.md §5.1 UHDR backup; §6.1 — 'time-limited, audited, revocable'; §6.3 researcher data flow
CATEGORY	Pure privacy failure
ISSUE	The consent engine describes user control over data at the device and NeurOne server level. But data shared with clinicians and researchers has no documented deletion-cascade path. When a user revokes clinician consent, NeurOne's access grant is terminated — but the clinician's own EHR system may retain UHDR-derived data indefinitely. This is the Sticky Third Parties anti-pattern: the user's data adheres to every system that touched it, and revocation only stops new flows.
REFERENCE	Sticky Third Parties anti-pattern; Obligation Management pattern; GDPR Art. 17(2) (controller must inform processors of erasure requests); HIPAA §164.528 (accounting of disclosures)
REMEDIATION	Clinician BAA must include: 'On notification of patient consent withdrawal, clinician will delete all copies of NeurOne-sourced patient data from their EHR and derived records within 30 days.' User-facing disclosure at revocation: NeurOne cannot delete data already in the clinic's system; they are contractually required to delete within 30 days. The per-user SHDR audit log (already specified) should list contributed studies; app Privacy Dashboard shows each entry with study ID, date, data elements — implementing the Privacy Dashboard pattern for research data.

Low Findings

LOW	App telemetry and crash reporting scope unspecified
WHERE	CLAUDE.md §10 iOS/Android app — Class B software; NP-SW-001 Rev 1
CATEGORY	Pure privacy failure
ISSUE	The iOS/Android app will ship with analytics and crash reporting, but neither vendor selection nor data scope is documented. Analytics event names reconstruct health-management behaviour (session_started, modality_toggled:tDCS, protocol_selected:depression). Crash reporters capture stack-local variables that may include session parameters or EEG state. If SDKs initialise before consent is captured, data is collected pre-consent. FTC enforcement against GoodRx (2023) and BetterHelp (2023) established that sharing health-app analytics with analytics vendors constitutes an HBNR breach even without names.
REFERENCE	Third-party Free-for-all anti-pattern; Full Payload Logging anti-pattern; GDPR Art. 7 (consent timing); FTC HBNR 16 CFR §318.3; GoodRx and BetterHelp FTC actions (2023)
REMEDIATION	Author NP-APP-TELEMETRY-001 before any SDK is added to the codebase. Contents: approved analytics vendor (maximum one, must provide DPA and BAA); approved crash reporter (maximum one, must support redacted payload mode); prohibited event properties (any health-inferable string, modality name, protocol name, UHDR token); permitted properties (app version, OS version, coarsened device model, anonymised local session counter). SDK initialisation gate: SDKs initialise only after consent flow is complete on first launch. Crash reporter: disable automatic payload capture; verify configuration by intentionally crashing in staging.

LOW	EU cross-border data transfer mechanism not specified
WHERE	CLAUDE.md §10 regulatory strategy — US only; §5.2 SHDR fleet telemetry; §6.1 T2 HIPAA cloud; §2.2 EU charger note
CATEGORY	Pure privacy failure (EU jurisdiction)
ISSUE	The regulatory strategy covers FDA pathways only. The EU charger note and global consumer positioning make clear EU users are anticipated. SHDR fleet uploads, warranty registration, and T2 clinical cloud serving EU users with US-hosted infrastructure constitute cross-border personal data transfers under GDPR Chapter V. Without a valid transfer mechanism, each transfer is unlawful under GDPR Art. 44. Transfers of health data require not just a Chapter V mechanism but confirmation that the third country provides essentially equivalent protection.
REFERENCE	GDPR Art. 44–49 (transfers to third countries); GDPR Art. 9 (health data transfer safeguards); EU-US Data Privacy Framework — effective July 2023; SCCs EC Implementing Decision 2021/914
REMEDIATION	Before EU T1 launch: add an EU regulatory section to CLAUDE.md and to NP-REG-001 (to be created). Fastest path: enroll in the EU-US Data Privacy Framework via self-certification on the DoC DPF website (4-6 weeks, minimal cost). Update privacy policy to reference DPF participation. For T2 clinical cloud: offer an EU-hosted deployment option (EEA cloud region) eliminating the transfer question for clinical data — also a competitive advantage with EU clinical buyers. Add GDPR Art. 13(1)(f) cross-border transfer disclosure to the app privacy notice.

LOW	Apple Watch sync app HealthKit data residency
WHERE	CLAUDE.md §3b Apple Watch Sync App — Phases 1-4; NP-APP-ROADMAP-001 Rev 1
CATEGORY	Pure privacy failure
ISSUE	Related to the HealthKit finding above: the roadmap does not explicitly state that HealthKit data accessed on the Watch stays on the Watch/iPhone and is not transmitted to NeurOne servers. Apple's guidelines require this, but it needs to be a binding engineering constraint documented in the spec — not just assumed. A future feature request to 'sync HRV trends to the NeurOne cloud' would constitute a HealthKit data transfer subject to both Apple guidelines and FTC HBNR.
REFERENCE	Apple HealthKit Review Guideline 5.1.1(iv); FTC HBNR 16 CFR §318.3; User-data confinement pattern
REMEDIATION	Add to NP-APP-ROADMAP-001 Rev 2 a binding data residency constraint for all HealthKit data: 'HealthKit data accessed by the Watch app is used for real-time session display only. It is not persisted, not cached, not transmitted to NeurOne servers or any third party, and not used for any purpose outside the active session.' Any future proposal to transmit HealthKit data requires a design change order with legal review and updated App Privacy Nutrition Label before implementation.

What Looks Good

✓ UHDR/SHDR separation is architecturally sound.

User-owned, biometric-key-encrypted health data the manufacturer cannot decrypt, separated from device-owned telemetry. Very few medical device companies implement this at the schema and firmware level.

✓ On-device research anonymisation is correct-by-design.

NeurOne never holds the decryption key and anonymisation happens on-device before any extract leaves. This makes consent withdrawal genuinely effective — rare and right.

✓ Boundary resolution rule has teeth.

'When in doubt → UHDR' is the only default that actually protects users and making it a design principle — not just a policy page — is the right instinct.

✓ The 4-layer research consent model is thoughtful.

The distinction between contact consent (L1), category consent (L2), blanket consent (L3), and results opt-in (L4) maps well to the progressive nature of research relationships. The irreversibility notice at both L3 and per-project invitation is legally accurate.

✓ Use-case-based clinical consent is better than field-based.

Having clinicians select use cases with the system determining minimum necessary elements is a correct application of the HIPAA Minimum Necessary Rule.

✓ SHDR fleet telemetry predictive maintenance model is legitimately privacy-preserving.

Routing LED degradation ratios and temperature profiles to SHDR (not UHDR) while using fleet-level ML for maintenance predictions is the 'send the answer, not the data' architecture.

✓ Consent withdrawal's forward-effectiveness guarantee is documented accurately.

The disclosure that published study data cannot be retracted but withdrawal stops all future flows — including from historical sessions — is both legally accurate and user-honest.

What You Couldn't Review

The following areas were not visible in the current documentation and represent gaps in this review's coverage.

■ iOS/Android app source code or API spec

All app-side findings are inferred from the roadmap. Actual telemetry configuration, third-party SDK list, cookie/storage handling, and consent flow implementation are unreviewed.

■ Warranty registration system

The Critical finding on warranty owner ID depends on how that system is built. The warranty database schema, access controls, retention, and join capabilities with the SHDR fleet database are not in scope of what was reviewed.

■ Clinical cloud architecture (T2)

The HIPAA cloud, FHIR R4 implementation, multi-patient dashboard, and scripting API are described at the feature level. The actual data model, access control implementation, and audit logging are unreviewed.

■ Vendor contracts

No DPAs, BAAs, or processor agreements were reviewed. The privacy quality of the architecture is partially a function of the contractual obligations on every vendor who touches NeurOne data.

■ Penetration test / threat model output

Security findings are based on architectural inference. A STRIDE+LINDDUN threat model pass on the hub firmware and clinical API, and an application penetration test on the iOS app and T2 cloud, would surface findings this review cannot.

Recommended Next Steps

- 1 Resolve Warranty Owner ID (Critical) — before any external beta or warranty registration**
~1 week engineering, 1 week legal. Highest regulatory exposure. Define the opaque token architecture and confirm in NP-FW-EMMC-001 Rev 2.
- 2 Author NP-SEC-BR-001 (Breach Response Plan) — Month 3 deliverable**
~3 days plus legal input. Hard deadlines (72 hours GDPR, 60 days HIPAA, 30 days most US state laws) cannot be met without a pre-existing runbook. Pre-T1-launch blocker.
- 3 Author NP-PROC-POA-001 (POA Upload Procedure) — before research consent infrastructure goes live**
~1 week. Encrypted upload, restricted-access vault, 30-day document deletion policy. The POA flow handles the most sensitive documents in the system with no documented controls.
- 4 Upgrade research anonymisation to I-diversity + differential privacy**
~2-4 weeks engineering in the on-device anonymisation engine. Protects against EEG re-identification attacks that k-anonymity alone cannot prevent.
- 5 Define Mode F as explicitly consented, separately toggled, default-off**
~1 sprint. Highest consent-gap finding in the modality stack; also touches retinal safety (IEC 62471). Default-off with ambient LED indicator is both the right privacy posture and the defensible regulatory posture.